

Narrativa explicativa del marco GQM + PRAGMATIC aplicado a hTMM

1. De hTMM al barro de los datos

El Hybrid Threat Modeling Method (hTMM) nació en el SEI con una ambición clara: combinar técnicas distintas (Security Cards, Persona non Grata, STRIDE) para lograr modelos de amenazas más completos, menos ruidosos y más repetibles, sin disparar los costes. [web:6][web:16] Hasta aquí, la música suena bien. El problema llega cuando intentamos traducir esa ambición a indicadores nacionales o sectoriales con los que comparar organizaciones, justificar inversiones o alimentar estrategias de ciberseguridad.

Para evitar que el modelado de amenazas se convierta en una especie de poesía épica sobre atacantes y vectores, hemos recurrido al viejo y eficaz enfoque GQM (Goal–Question–Metric): empezar por los objetivos, formular las preguntas que realmente importan y, solo entonces, decidir qué métricas tiene sentido recoger. [web:32][web:34][web:38]

2. Objetivos sin eufemismos

Los objetivos macro (G) que se han derivado del informe original de indicadores HTMM y del paisaje europeo de amenazas (ENISA TL 2025) son bastante terrenales: [web:6][web:16][web:13][web:7]

- Saber si estamos modelando las amenazas adecuadas (cobertura).
- Saber si distintos equipos/organizaciones llegan a conclusiones razonablemente parecidas (consistencia y ruido).
- Saber si el esfuerzo que invertimos tiene sentido económico (esfuerzo y costo-efectividad).
- Saber si lo que sale del modelado se convierte en requisitos, controles y decisiones de riesgo reales (trazabilidad).
- Saber si todo esto está alineado con el entorno europeo y sus tendencias de amenazas (conexión con ENISA y la UE).

A partir de ahí, se han construido preguntas (Q) que descienden un escalón: ¿cuántas categorías STRIDE cubrimos?, ¿cómo de divergentes son los catálogos de amenazas entre equipos?, ¿qué porcentaje de amenazas acaba teniendo un control asociado?, etc. [web:6][web:16]

3. Las métricas: ni pocas ni muchas, sino útiles

Cada conjunto de preguntas se traduce en métricas (M) que pueden ser medidas sin montar una expedición antropológica en cada organización. Algunas son casi obvias («horas totales por sesión de modelado»); otras requieren un poco más de disciplina («porcentaje de amenazas internas con categoría ENISA asignada»). [web:13][web:7]

El criterio rector ha sido doble:

1. Que las métricas conecten de forma trazable con los objetivos (G) vía las preguntas (Q).
2. Que puedan responder a cuestiones que importan de verdad a un responsable nacional/sectorial: ¿qué tan cubiertos estamos?, ¿en qué se nos va el tiempo?, ¿qué parte de esto se convierte en controles?, ¿estamos alineados con el paisaje de amenazas europeo? [web:13][web:7]

4. Por qué PRAGMATIC (y no otra sigla más)

Por muy elegante que sea GQM, de nada sirve coleccionar métricas si no evaluamos su calidad. Aquí entra PRAGMATIC: un acrónimo incómodamente largo que recuerda que una métrica, para ser digna de ese nombre, debe ser predictiva, relevante, accionable, genuina, significativa, precisa, oportuna, independiente y coste-efectiva.

El ejercicio de puntuar cada métrica con estos criterios tiene dos efectos colaterales saludables:

- Obliga a descartar métricas “bonitas” en papel pero caras, imprecisas o no accionables.
- Da munición argumental cuando alguien pide «un cuadro de mando con muchas cosas», sin preguntarse si alguien las leerá.

La matriz PRAGMATIC propuesta en este kit no está pensada como tablilla sagrada, sino como punto de partida para que cada país, sector u organización ajuste las puntuaciones a su realidad.

5. Cómo se ensambla todo: de los objetivos al IGM

El flujo completo puede resumirse así:

3. Definimos objetivos de alto nivel (G1–G5) alineados con hTMM y el contexto europeo.
4. Derivamos preguntas que aterrizan esos objetivos en ámbitos concretos (cobertura, consistencia, esfuerzo, trazabilidad, alineación ENISA).
5. Elegimos métricas para responder a esas preguntas de forma cuantificable.
6. Evaluamos las métricas con PRAGMATIC y seleccionamos un subconjunto robusto.
7. Asignamos pesos por bloques y métricas para construir un Indicador Global de Madurez (IGM) que pueda compararse entre sectores y a lo largo del tiempo.

Ese IGM no pretende capturar toda la riqueza del modelado de amenazas, pero sí ofrecer una brújula que señale quién está usando hTMM (o enfoques análogos) como herramienta estratégica y quién lo mantiene en el cajón de «cosas que hacemos cuando viene el auditor».

6. Qué puede hacer un país (o sector) con este marco

Con el marco GQM + PRAGMATIC aplicado a hTMM, los responsables nacionales y sectoriales pueden:

- Diseñar encuestas y mecanismos de reporting que no se limiten a preguntar “¿tiene usted modelado de amenazas, sí o no?”, sino que capturen calidad, cobertura, integración y alineación con el entorno europeo.
- Comparar sectores críticos entre sí, detectando dónde hay modelos de amenazas razonablemente maduros y dónde todavía predominan las listas de deseos.
- Priorizar iniciativas: formación, guías, herramientas, requisitos regulatorios, etc., con base en lagunas concretas de métricas.
- Medir la evolución en el tiempo, enlazando mejoras en el IGM con cambios en la exposición a incidentes (por ejemplo, reducciones en ciertos tipos de incidentes prevalentes según ENISA TL 2025). [web:13][web:7]

El resultado ideal no es un país obsesionado con sus métricas, sino uno que usa esas métricas como espejo y palanca para reforzar su capacidad de anticipar, modelar y mitigar amenazas en un ecosistema cada vez más híbrido.